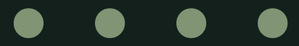
LE DÉFI · ACCÉDER AU COMPTE ADMINISTRATEUR

Un compte admin. Deux portes d’entrée.

CONNEXION CLASSIQUE



Email + mot de passe

Le mot de passe de l’admin reste inconnu.

CONNEXION GOOGLE

ATTESTATION D’IDENTITÉ

Numéro du compte

« Voici qui se connecte. »

Une attestation transmise au site

Le site lit le numéro du compte.

LA FAILLE

Sur le chemin « legacy », **le site ne vérifiait pas la signature.**

LES IMPASSES · CHANGER LE RÔLE NE SUFFIT PAS

Écrire « admin » ne rendait pas admin.

✕ **Ajouter « rôle : admin »**
Le site ignore cette demande.

UTILISATEUR

✕ **Copier l'email de l'admin**
Avec un autre identifiant, cela crée un autre compte.

UTILISATEUR

LE CHAMP QUI COMPTE

`sub`

Le numéro qui désigne **un compte Google précis.**

→

Retrouver le compte existant, avec son rôle enregistré.

L'IDÉE À RETENIR

Il fallait retrouver **l'identifiant du vrai compte admin.**

LE DÉCLIC · L’INDICE ÉTAIT AU PIED DE LA PAGE

Le numéro était trouvable.
Le site le traitait comme un secret.

01

Le pied de page

Tech Corp Chandler

Une adresse Gmail de contact

Un indice sur l’identité de l’admin.

02

La recherche du compte

Google People API

Avec une session Google de test

L’adresse permet ici de retrouver un identifiant.

03

Le bon numéro

`1034…4574`

GAIA ID / sub · abrégé

À placer dans l’attestation fabriquée.

L’IDÉE À RETENIR

Le déclic : **chercher l’identité** au lieu de deviner un mot de passe.

LE RÉSULTAT · SOLVE CONSIGNÉ À 21:25

Le bon identifiant.
Une session administrateur.

Attestation fabriquée → Compte existant retrouvé → ADMIN

EXTRAIT DU WRITE-UP CONSERVÉ · TRANSCRIPTION

socialLogin	memberId: 1 · role: admin
/api/flag	flag retourné

Le endpoint « /api/admin/flag » était un leurre : même connecté, il renvoyait 404.

BA26{sub_is_not_a_secret_but_treating_it_like_a_password_is}

L'IDÉE À RETENIR

Vérifier **la preuve d'identité**, pas seulement lire le numéro.